

Tài liệu Test Case — Admin User Management

Module: Quản lý người dùng (Admin)
Phụ trách: BE2
Sprint: Tuần 3 (25/05 – 31/05/2026)
Môi trường: Local — <http://127.0.0.1:8000/api/v1>
Công cụ: Postman
Người tạo: BE2
Ngày tạo: 12/06/2026

Điều kiện tiên quyết chung

Tài khoản	Email	Mật khẩu	Role	Trạng thái
Admin Demo	admin@homi.test	123456	admin	active
Staff Demo	staff@homi.test	123456	staff	active
Customer Demo	customer@homi.test	123456	customer	active

Trước mỗi nhóm test, đăng nhập lấy Bearer Token của tài khoản tương ứng.
Endpoint đăng nhập: **POST** [/api/v1/login](#) → lấy **token** từ response.

Nhóm 1 — Lọc danh sách user theo role

TC-USER-001 — Lọc role=customer

Trường	Nội dung
ID	TC-USER-001
Chức năng	Lọc danh sách user theo role customer
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản admin, có Bearer Token
Dữ liệu đầu vào	GET /api/v1/admin/users?role=customer
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi GET request với header Authorization: Bearer {token} và query role=customer
Kết quả mong đợi	HTTP 200 — success: true — mảng users chỉ chứa user có role = "customer" — có meta phân trang
Kết quả thực tế	<i>(để trống — điền sau khi test)</i>
Trạng thái	☐ Pass ☐ Fail

TC-USER-002 — Lọc role=staff

Trường	Nội dung
ID	TC-USER-002
Chức năng	Lọc danh sách user theo role staff
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản admin
Dữ liệu đầu vào	GET /api/v1/admin/users?role=staff
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi GET request với query role=staff
Kết quả mong đợi	HTTP 200 — mảng users chỉ chứa user có role = "staff"
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-003 — Lọc role=admin

Trường	Nội dung
ID	TC-USER-003
Chức năng	Lọc danh sách user theo role admin
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản admin
Dữ liệu đầu vào	GET /api/v1/admin/users?role=admin
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi GET request với query role=admin
Kết quả mong đợi	HTTP 200 — mảng users chỉ chứa user có role = "admin"
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-004 — Không lọc role (trả tất cả)

Trường	Nội dung
ID	TC-USER-004
Chức năng	Lấy danh sách tất cả user không có bộ lọc
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản admin
Dữ liệu đầu vào	GET /api/v1/admin/users

Trường	Nội dung
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi GET request không có query
Kết quả mong đợi	HTTP 200 — <code>users</code> chứa tất cả user (customer + staff + admin) — <code>meta.total</code> <code>>= 3</code>
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-005 — Lọc role không hợp lệ

Trường	Nội dung
ID	TC-USER-005
Chức năng	Validation khi truyền role sai giá trị
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản admin
Dữ liệu đầu vào	<code>GET /api/v1/admin/users?role=superadmin</code>
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi GET request với query <code>role=superadmin</code>
Kết quả mong đợi	HTTP 422 — <code>success: false</code> — <code>errors.role</code> chứa thông báo lỗi validation
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-006 — Tìm kiếm user theo tên

Trường	Nội dung
ID	TC-USER-006
Chức năng	Tìm kiếm user theo từ khóa tên
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản admin
Dữ liệu đầu vào	<code>GET /api/v1/admin/users?search=Customer</code>
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi GET request với query <code>search=Customer</code>
Kết quả mong đợi	HTTP 200 — <code>users</code> chứa các user có <code>name</code> chứa "Customer"
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-007 — Staff lọc danh sách user (được phép)

Trường	Nội dung
ID	TC-USER-007
Chức năng	Staff có quyền xem danh sách user
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản staff
Dữ liệu đầu vào	GET /api/v1/admin/users
Bước thực hiện	1. Đăng nhập staff lấy token 2. Gửi GET request
Kết quả mong đợi	HTTP 200 — trả danh sách user bình thường
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-008 — Customer không được xem danh sách user

Trường	Nội dung
ID	TC-USER-008
Chức năng	Customer bị từ chối truy cập endpoint admin
Điều kiện tiên quyết	Đã đăng nhập bằng tài khoản customer
Dữ liệu đầu vào	GET /api/v1/admin/users
Bước thực hiện	1. Đăng nhập customer lấy token 2. Gửi GET request
Kết quả mong đợi	HTTP 403 — success: false — thông báo không có quyền
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-009 — Không đăng nhập truy cập danh sách user

Trường	Nội dung
ID	TC-USER-009
Chức năng	Chưa đăng nhập bị từ chối
Điều kiện tiên quyết	Không có Bearer Token
Dữ liệu đầu vào	GET /api/v1/admin/users (không header Authorization)
Bước thực hiện	Gửi GET request không có token
Kết quả mong đợi	HTTP 401 — success: false — "Bạn chưa đăng nhập."

Trường	Nội dung
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

Nhóm 2 — Khóa / mở khóa tài khoản

TC-USER-010 — Admin khóa tài khoản customer

Trường	Nội dung
ID	TC-USER-010
Chức năng	Admin khóa tài khoản user đang active
Điều kiện tiên quyết	Đã đăng nhập admin — tài khoản customer đang <code>status = active</code>
Dữ liệu đầu vào	<code>PATCH /api/v1/admin/users/{customer_id}/toggle-status</code>
Bước thực hiện	1. Đăng nhập admin lấy token 2. Lấy <code>id</code> của customer (TC-USER-001) 3. Gửi PATCH request với <code>{customer_id}</code>
Kết quả mong đợi	HTTP 200 — <code>success: true</code> — <code>user.status = "locked"</code> — message "Đã khóa tài khoản..."
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-011 — Admin mở khóa tài khoản đang bị khóa

Trường	Nội dung
ID	TC-USER-011
Chức năng	Admin mở khóa user đang locked
Điều kiện tiên quyết	Đã đăng nhập admin — customer đang <code>status = locked</code> (chạy sau TC-USER-010)
Dữ liệu đầu vào	<code>PATCH /api/v1/admin/users/{customer_id}/toggle-status</code>
Bước thực hiện	1. Dùng token admin 2. Gửi PATCH request lần 2 với cùng <code>{customer_id}</code>
Kết quả mong đợi	HTTP 200 — <code>user.status = "active"</code> — message "Đã mở khóa tài khoản..."
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-012 — Admin tự khóa chính mình

Trường	Nội dung
ID	TC-USER-012
Chức năng	Ngăn admin khóa tài khoản đang dùng
Điều kiện tiên quyết	Đã đăng nhập admin, biết <code>id</code> của admin
Dữ liệu đầu vào	<code>PATCH /api/v1/admin/users/{admin_id}/toggle-status</code>
Bước thực hiện	1. Đăng nhập admin lấy token và <code>id</code> từ <code>GET /api/v1/me</code> 2. Gửi PATCH request với chính <code>admin_id</code> đó
Kết quả mong đợi	HTTP 422 — <code>success: false</code> — message "Không thể khóa tài khoản của chính mình."
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-013 — Staff cố khóa user (không có quyền)

Trường	Nội dung
ID	TC-USER-013
Chức năng	Staff không được phép khóa user
Điều kiện tiên quyết	Đã đăng nhập staff
Dữ liệu đầu vào	<code>PATCH /api/v1/admin/users/{customer_id}/toggle-status</code>
Bước thực hiện	1. Đăng nhập staff lấy token 2. Gửi PATCH request
Kết quả mong đợi	HTTP 403 — <code>success: false</code> — thông báo không có quyền
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-014 — Khóa user không tồn tại

Trường	Nội dung
ID	TC-USER-014
Chức năng	Toggle status với ID user không có trong DB
Điều kiện tiên quyết	Đã đăng nhập admin
Dữ liệu đầu vào	<code>PATCH /api/v1/admin/users/99999/toggle-status</code>

Trường	Nội dung
Bước thực hiện	1. Đăng nhập admin lấy token 2. Gửi PATCH request với id=99999
Kết quả mong đợi	HTTP 404 — success: false — "Không tìm thấy dữ liệu."
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

Nhóm 3 — User bị khóa không đăng nhập được

TC-USER-015 — User bị khóa cố đăng nhập

Trường	Nội dung
ID	TC-USER-015
Chức năng	Tài khoản locked không thể đăng nhập
Điều kiện tiên quyết	Customer đang status = locked (chạy TC-USER-010 trước)
Dữ liệu đầu vào	POST /api/v1/login body: { "email": "customer@homi.test", "password": "123456" }
Bước thực hiện	1. Đảm bảo customer đang bị khóa (TC-USER-010) 2. Gửi POST login với đúng email + mật khẩu của customer bị khóa
Kết quả mong đợi	HTTP 403 — success: false — message "Tài khoản đã bị khóa."
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-016 — User bị khóa đăng nhập sai mật khẩu

Trường	Nội dung
ID	TC-USER-016
Chức năng	Tài khoản locked + sai mật khẩu → ưu tiên báo sai mật khẩu
Điều kiện tiên quyết	Customer đang status = locked
Dữ liệu đầu vào	POST /api/v1/login body: { "email": "customer@homi.test", "password": "wrongpass" }
Bước thực hiện	1. Đảm bảo customer đang bị khóa 2. Gửi POST login với sai mật khẩu

Trường	Nội dung
Kết quả mong đợi	HTTP 401 — message "Email hoặc mật khẩu không đúng."
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

TC-USER-017 — Mở khóa xong user đăng nhập được lại

Trường	Nội dung
ID	TC-USER-017
Chức năng	Sau khi mở khóa, user đăng nhập bình thường
Điều kiện tiên quyết	Customer đã được mở khóa (TC-USER-011)
Dữ liệu đầu vào	POST /api/v1/login body: { "email": "customer@homi.test", "password": "123456" }
Bước thực hiện	1. Mở khóa customer bằng TC-USER-011 2. Gửi POST login với đúng thông tin
Kết quả mong đợi	HTTP 200 — success: true — có token trong response
Kết quả thực tế	(để trống)
Trạng thái	☐ Pass ☐ Fail

Tổng hợp

ID	Chức năng	Nhóm	Trạng thái
TC-USER-001	Lọc role=customer	Lọc role	☐
TC-USER-002	Lọc role=staff	Lọc role	☐
TC-USER-003	Lọc role=admin	Lọc role	☐
TC-USER-004	Không lọc — trả tất cả	Lọc role	☐
TC-USER-005	Lọc role không hợp lệ → 422	Lọc role	☐
TC-USER-006	Tìm kiếm theo tên	Lọc role	☐
TC-USER-007	Staff được xem danh sách	Phân quyền	☐
TC-USER-008	Customer bị từ chối → 403	Phân quyền	☐
TC-USER-009	Chưa đăng nhập → 401	Phân quyền	☐

ID	Chức năng	Nhóm	Trạng thái
TC-USER-010	Admin khóa customer → locked	Khóa user	☐
TC-USER-011	Admin mở khóa → active	Khóa user	☐
TC-USER-012	Admin tự khóa mình → 422	Khóa user	☐
TC-USER-013	Staff khóa user → 403	Khóa user	☐
TC-USER-014	User không tồn tại → 404	Khóa user	☐
TC-USER-015	User bị khóa đăng nhập → 403	Bị khóa	☐
TC-USER-016	User bị khóa + sai pass → 401	Bị khóa	☐
TC-USER-017	Mở khóa xong đăng nhập lại được	Bị khóa	☐

Tổng: 17 test case | **Pass:** — | **Fail:** —